ПОЛОЖЕНИЕ О ПОЛИТИКЕ ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ ОРГАНИЗАЦИИ «ВАСЬТЕХНОЛОДЖИС».

1. Введение

1.1 Назначение документа.

Настоящие документ определяет цели, задачи, принципы и правила обеспечения информационной безопасности в рамках организации «ВАСЬТЕХНОЛОДЖИС».
Сфера деятельности организации: «ВАСЬТЕХНОЛОДЖИС» осуществляет деятельность в сфере информационных технологий, включая разработку программного обеспечения, администрирование облачных сервисов и обработку данных клиентов. В связи с этим ключевыми цифровыми активами организации, подлежащими защите, являются: исходный код разрабатываемых продуктов, базы данных пользователей, коммерческая тайна и ИТ-инфраструктура.
Политика является основополагающим регламентом для настройки межсетевого экрана OPNsense, операционных систем Ubuntu Server, рабочих станций и системы мониторинга Wazuh.

1.2 Общие принципы защиты.

Защита организации строится на основе двух фундаментальных концепций современной кибербезопасности:
- ZeroTrust (Нулевое доверие): ни один субъект или объект сети не считается доверенным по умолчанию, независимо от его физического или сетевого расположения. Любое действие должно быть явно разрешено и аутентифицировано.
- Defense in Depth (Глубоко эшелонированная защита): создание нескольких барьеров на пути потенциального злоумышленника (сетевой шлюз → локальный файрвол ОС → защита учетных записей → система автоматического отпора Active Response).

1.3 Нормативно-правовая база.

Настоящее Положение разработано в соответствии с законодательством РФ, регламентирующим вопросы защиты информации и персональных данных включая:
- ФЗ №152 «О персональных данных» - в части обеспечения конфиденциальности, целостности и доступности обрабатываемых персональных данных, сотрудников и клиентов.
- ФЗ №152 «Об информации, информационных технологиях и о защите информации» - в части ограничения доступа к конфиденциальной информации и защиты инфраструктуры организации.
- ФЗ №98 «О коммерческой тайне» - в части защиты конфиденциальной информации, составляющей коммерческую тайну организации, а также регулирования отношений, связанных с установлением, изменением и прекращения режима коммерческой тайны.

2. Архитектура сети и сегментация.

2.1 Разграничение сетевых зон.
Вся инфраструктура организации разделяется на изолированные сегменты (VLAN/подсети) с контролем трафика на межсетевом экране OPNsense:
- Зона управления и безопасности (Management / Security Zone): сегмент для размещения сервера Wazuh и интерфейса администрирование OPNsense. Доступ строго ограничен.
- Зона корпоративных серверов (DMZ / Server Zone): сегмент для серверов корпорации на Ubuntu Server. Доступ разрешен только по необходимым для работы портам.
- Зона рабочих станций (LAN / Workstation Zone): сегмент для имитации рабочих мест сотрудников. Прямой доступ между рабочими станциями внутри зоны запрещен.
- Внешняя зона (WAN): интернет или внешняя недоверенная сеть.

2.2 Правила фильтрации сетевого трафика.
Сетевой межсетевой экран OPNsense функционирует по принципу «запрещено все, что явно не разрешено». Доступ из зоны рабочих станций в зону управления запрещен. Под исключением базируется отправка логов агента Wazuh на сервер по строго отведенным портам (например 1515/TCP). Доступ из внешней сети WAN к серверам и рабочим станциям полностью заблокирован. Управление инфраструктурой из WAN допускается только через защищенный VPN-тунелль с двухфакторной аутентификацией.

3. Политика безопасности операционных систем и узлов.

3.1 Защита серверов и рабочих станций.
- Минимизация поверхности атаки: на ОС устанавливается только минимально необходимый набор пакетов. Все неиспользуемые службы и демоны должны быть отключены и удалены.
- Локальный межсетевой экран: на каждом узле должен быть активен и настроен локальный файрфол (для примера UFW), дублирующий правила периметра по принципу эшелонирования.
- Управление доступом: прямой вход по учетной записью root по SSH запрещен. Аутентификация по SSH осуществляется строго по асимметричным ключам. Аутентификация по паролям отключается. Для выполнения административных задач используется механизм sudo с обязательным логированием действий.
- Политика паролей: первичные пароли и учетные данные для доступа к корпоративным ресурсам генерируются и выдаются Службой безопасности лично каждому сотруднику под подпись. Использование простых, стандартных или самостоятельно придуманных сотрудниками паролей без согласования со Службой безопасности для критических систем запрещено.

3.2 Обновление программного обеспечения.
На серверах и рабочих станциях настраивается автоматическая установка обновлений безопасности.

3.3 Безопасность рабочих мест и персональная ответственность сотрудников.
- Персональная ответственность: каждый сотрудник организации несет персональную (дисциплинарную / материальную) ответственность за сохранность вверенных ему конфиденциальных данных и исправность работы АРМ.
- Компрометация учетных данных: сотрудникам строго запрещается передавать свои пароли, сессионные ключи или токены третьим лицам, а также записывать их на физических носителях, находящихся в открытом доступе.
- Политика чистого АРМ и блокировка: при любом, даже кратковременном, покидании рабочего места сотрудник обязан заблокировать экран АРМ (сочетание клавиш WIN + L). Оставлять АРМ в активном состоянии без присмотра категорически запрещено.
- Защита информации о рабочих процессах: сотрудникам строго запрещается распространять, публиковать или передавать третьим лицам любую конфиденциальную информацию о внутренних рабочих процессах, архитектуре сети «ВАСЬТЕХНОЛОДЖИС», используемом ПО, а также о применяемых мерах защиты.
- Ответственность за разглашение: в соответствии с ФЗ №98 «О коммерческой тайне», за разглашение или несанкционированное распространение сведений, составляющих коммерческую тайну или конфиденциальную информацию организации, сотрудники несут персональную дисциплинарную, гражданско-правовую, административную или уголовную ответственность вплоть до увольнения и возмещения убытков.

3.4 Обеспечение режима коммерческой тайны и технические меры ограничения доступа.
В целях выполнения требований ФЗ №98 «О коммерческой тайне» и легитимного привлечения к ответственности за ее разглашение, в организации «ВАСЬТЕХНОЛОДЖИС» вводятся следующие обязательные меры ограничения доступа к конфиденциальной информации:
- Шифрование данных (Криптографическая защита): передача любой информации, составляющей коммерческую тайну, по открытым каналам связи в незашифрованном виде запрещена. Все корпоративные каналы связи (VPN), а также критические накопители серверов и рабочих станций подлежат обязательному шифрованию и использованием стойких алгоритмов.
- Разграничение прав по принципу минимальных привилегий: доступ к файлам, исходному коду и базам данных предоставляется сотрудниками строго на основании их должностных обязанностей. Отсутствие явного разрешения на доступ приравнивается к запрету.

- Маркировка и грифы: все электронные и физические документы, содержащие конфиденциальные сведения, должны иметь маркировку «Коммерческая тайна ВАСЬТЕХНОЛОДЖИС» с указанием правообладателя и его места нахождения.
- Регистрация и аудит доступа: любые действия по чтению, изменению или копированию информации, составляющей коммерческую тайну, непрерывно фиксируются системой мониторинга Wazuh SIEM. Логи доступа признаются легитимным доказательством проведения внутреннего расследования.

3.5 Политика резервного копирования.
Для обеспечения непрерывности бизнес-процессов и гарантированного восстановления данных в случае сбоев или кибератак, вводится регламент резервного копирования.
- Правило 3-2-1: хранить не менее 3 копий данных, использовать 2 разных типа носителей для хранения и 1 копию отправлять за пределы основной инфраструктуры (изолированный бэкап сервер).
- Изоляция бэкапов: сервер резервного копирования должен находиться в изолированном сетевом сегменте OPNsense. Доступ к нему со стороны рабочих станций и обычных серверов Ubuntu должен быть полностью заблокирован на сетевом уровне. Допускается только инициирование забора данных самим бэкап-сервером.
- Шифрование и грубина хранения: все резервные копии, содержащие коммерческую тайну или персональные данные, подлежат обязательному шифрованию. Глубина хранения архивов составляет не менее 30 дней.
- Проверка восстановления: Администратор безопасности совместно со службой ИТ обязан раз в месяц проводить тестовое восстановление систем из резервных копий для проверки их целостности.

4. Мониторинг, аудит и автоматическое реагирование.

4.1 Централизованный сбор логов Wazuh SIEM.
На все серверы и рабочие станции организации в обязательном порядке устанавливается агент мониторинга Wazuh Agent. Агенты должны непрерывно передавать на сервер Wazuh следующие события: все попытки аутентификации (удачные / неудачные), изменения критических системных файлов (модуль File Integrity Monitoring), запуск процессов от имени sudo, логи локальных межсетевых экранов.
4.2 Политика автоматического отпора Active Response.
Для предотвращения развития компьютерных атак внедряется подсистема автоматического реагирования Wazuh Active Response. Блокировка брутфорса: при фиксации кратных неудачных попыток авторизации по SSH, IP адрес атакующего автоматически блокируется локальным сервером (UFW) на заданное время. Реагирование на аномалии: при обнаружении подозрительной активности или известных веб-уязвимостей на корпоративном сервере, Active Response изолирует скомпрометированный узел на уровне сети или завершает вредоносный процесс.

4.3 Регламент реагирования на инциденты информационной безопасности.
При обнаружении признаков компрометации (оповещение Wazuh, аномальный трафик на OPNsense, шифрование файлов), сотрудники и администраторы обязаны действовать по следующему алгоритму:
- Локализация (Изоляция): при подозрении на заражение рабочей станции или сервера, узел должен быть немедленно отключен от сети (физически или через блокировку порта OPNsense / команду Active Response в Wazuh). Выключать питание устройства из розетки запрещено, чтобы сохранить следы атаки в оперативной памяти RAM.
- Фиксация и анализ: Администратор информационной безопасности собирает логи Wazuh, OPNsense и системные журналы Ubuntu для определения вектора атаки, масштаба ущерба и источника угрозы.
- Искоренение и восстановление: проводится удаление вредоносного ПО, закрытие уязвимостей(патчинг, изменение правил файрвола), после чего системы восстанавливаются из доверенных резервных копий.
- Разбор инцидента: каждый критический инцидент документируется с внесением изменений в настоящую Политику и настройки систем безопасности для предотвращения повторных атак.

5. Регламент контроля и проверки защищенности.

5.1 Симуляция инцидентов.
Администратор безопасности обязан проводить регулярные искусственные тесты защиты для проверки эффективности правил Wazuh и Active Response. Каждая симуляция, например сканирование портов с помощью nmap, попытка подбора пароля SSH hydra, изменение файла /etc/passwd должна корректно отображаться в панели Wazuh и вызывать соответствующий хук реагирования.
5.2 Контроль целостности политики.
Любые изменения в конфигурации OPNsense, серверов Wazuh должны быть задокументированы. Раз в неделю проводится сверка текущих настроек с требованиями настоящего Положения.